

SECURITY ASSESSMENT

Reporte de Análisis de Vulnerabilidades

Ejemplo

PRODUCTO	Entitlement_NU0141001
TIPO	Vulnerability Assessment Report
FECHA	21 de mayo de 2026
VERSIÓN	1.0

150

TOTAL

16

CRITICAL

47

HIGH

57

MEDIUM

Entitlement Security — Generado automáticamente

Contenido

01	Resumen Ejecutivo	3
02	Análisis por Tipo de Vulnerabilidad	4
03	Análisis por Servicio y Severidad	5
04	Detalle de Vulnerabilidades	6
05	Top 10 Vulnerabilidades Más Urgentes	-
06	Análisis de SLA	-
07	Vulnerabilidades Compartidas	-
08	Componentes Más Vulnerables	-
09	Cobertura de Mitigación	-
10	Herramientas y Ambientes	-

Este reporte contiene información clasificada como CONFIDENCIAL. Su distribución está restringida al equipo de seguridad y stakeholders autorizados.

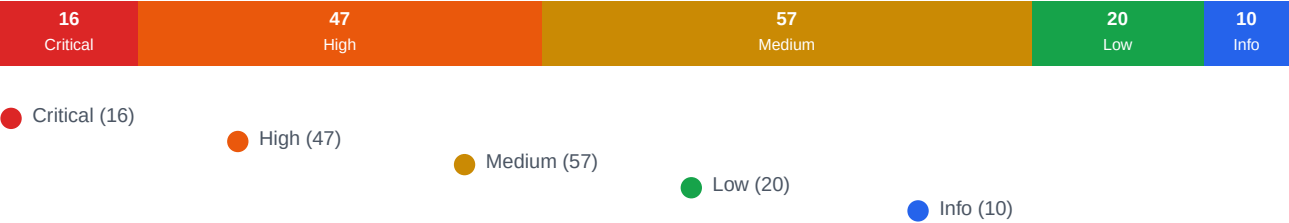
SECCIÓN 01

Resumen Ejecutivo

Se identificaron un total de 150 vulnerabilidades activas en el análisis actual. El siguiente resumen presenta los indicadores clave de riesgo y la distribución por severidad.



Distribución por Severidad



Severidad	Cantidad	% del Total	Riesgo
● CRITICAL	16	10.7%	ALTO
● HIGH	47	31.3%	ALTO
● MEDIUM	57	38.0%	MEDIO
● LOW	20	13.3%	BAJO
● INFO	10	6.7%	BAJO

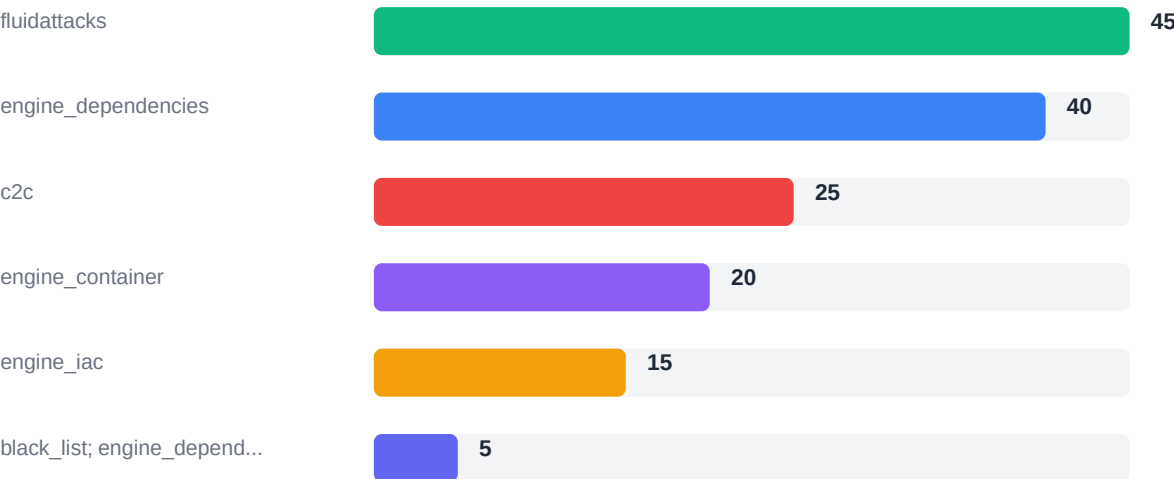
SECCIÓN 02

Análisis por Tipo de Vulnerabilidad

Clasificación de vulnerabilidades según su tipo de escaneo o fuente de detección:

Tipo (Tag)	Cantidad	% del Total
fluidattacks	45	30.0%
engine_dependencies	40	26.7%
c2c	25	16.7%
engine_container	20	13.3%
engine_iac	15	10.0%
black_list; engine_dependencies	5	3.3%

Vulnerabilidades por Tipo



Descripción de Tipos

- engine_dependencies**: Vulnerabilidades en dependencias/librerías del proyecto.
- c2c**: Vulnerabilidades de Continuous Compliance (configuración AWS).
- engine_container**: Vulnerabilidades en contenedores Docker.
- engine_iac**: Vulnerabilidades en infraestructura como código (IaC).

- **fluidattacks**: Vulnerabilidades detectadas por Hacking Continuo (Fluid Attacks).
- **black_list; engine_dependencies**: Dependencias en lista negra.

SECCIÓN 03

Análisis por Servicio y Severidad

Distribución de vulnerabilidades por servicio (engagement) y nivel de severidad:

Servicio	Info	Low	Med	High	Crit	Total
DEMO_001_FakeBank_MR_ms_cuentas	2	4	11	9	4	30
DEMO_002_FakeShop_MR_ms_pedidos	2	4	11	10	3	30
DEMO_003_FakeLogistic_MR_ms_envios	2	4	11	10	3	30
DEMO_004_FakeInsurance_MR_ms_polizas	2	4	12	9	3	30
DEMO_002_FakeShop_TEST_ms_pedidos_test	2	4	12	9	3	30

SECCIÓN 04

Detalle de Vulnerabilidades por Servicio

Vulnerabilidades únicas por servicio, organizadas por tipo. Dentro de cada tipo: primero servicios productivos, luego servicios de test.

4.1 Hacking Continuo (Fluid Attacks)

Vulnerabilidades detectadas mediante pentesting continuo por Fluid Attacks.

Total vulnerabilidades: 45 | Servicios afectados: 5

> Servicios Productivos

DEMO_001_FakeBank_MR_ms_cuentas

Producto: Demo_DEMO001 | Vulnerabilidades: 9

1. Broken Authentication: Session tokens with insufficient entropy - Demo 1

● CRITICAL

Tipo: fluidattacks | CVE: CVE-2025-99001 com.demo_fake-crypto-lib 1.2.3 | Prioridad: 0.01

Archivo: src/main/com.demo/fake-crypto-lib/demo_1.java

The session management module generates tokens with only 32 bits of entropy using a predictable PRNG seeded with system time.

[Fix] Upgrade com.fake:demo-session-manager to 3.0.0 or replace token generation with java.security.SecureRandom with at least 128-bit entropy.

2. Broken Authentication: Session tokens with insufficient entropy - Demo 146

● CRITICAL

Tipo: fluidattacks | CVE: CVE-2025-99001 org.example_demo-http-client 2.1.0 | Prioridad: 0.01

Archivo: src/main/org.example/demo-http-client/demo_146.java

The session management module generates tokens with only 32 bits of entropy using a predictable PRNG seeded with system time.

[Fix] Upgrade com.fake:demo-session-manager to 3.0.0 or replace token generation with java.security.SecureRandom with at least 128-bit entropy.

3. Insecure Direct Object Reference in policy document download - Demo 6

● HIGH

Tipo: fluidattacks | CVE: CVE-2025-99006 com.fake_demo-session-manager 2.3.4 | Prioridad: 0.01

Archivo: src/main/com.fake/demo-session-manager/demo_6.java

The policy download endpoint accepts a numeric document ID as a URL parameter without verifying ownership.

[Fix] Upgrade io.demo:fake-db-driver to 4.5.9 and implement resource-level authorization checks on every download request.

4. SQL Injection via unparameterized dynamic query builder - Demo 31

● HIGH

Tipo: fluidattacks | CVE: CVE-2025-99002 io.example_demo-auth-lib 5.1.0 | Prioridad: 0.01

Archivo: src/main/io.example/demo-auth-lib/demo_31.java

The user search endpoint concatenates user-supplied input directly into SQL statements without sanitization.

[Fix] Upgrade io.example:demo-auth-lib to 5.1.3 and replace all dynamic query construction with prepared statements.

5. Sensitive Data Exposure: Cryptographic keys stored in source code - Demo 61

● HIGH

Tipo: fluidattacks | CVE: CVE-2025-99003 com.demo_fake-crypto-lib 1.2.3 | Prioridad: 0.01

Archivo: src/main/com.demo/fake-crypto-lib/demo_61.java

AES-128 encryption keys are hardcoded in the application source code and committed to the version control history.

[Fix] Rotate all exposed keys immediately. Move secrets to a vault solution (e.g. HashiCorp Vault or AWS Secrets Manager). Remove key material from git history.

6. Open Redirect via unvalidated returnUrl query parameter - Demo 66

● MEDIUM

Tipo: fluidattacks | CVE: CVE-2025-99008 com.fake_demo-session-manager 2.3.4 | Prioridad: 0.01

Archivo: src/main/com.fake/demo-session-manager/demo_66.java

The login flow in the test environment accepts an arbitrary returnUrl parameter and redirects the user post-authentication

[Fix] Upgrade org.example:demo-http-client to 2.1.4 and implement an allowlist of valid redirect destinations.

7. Cross-Site Scripting (Reflected) in error response body - Demo 91

● MEDIUM

Tipo: fluidattacks | CVE: CVE-2025-99004 io.example_demo-auth-lib 5.1.0 | Prioridad: 0.01

Archivo: src/main/io.example/demo-auth-lib/demo_91.java

Error messages rendered by the XML parser module reflect unescaped request parameters into the HTML response.

[Fix] Upgrade org.demo:fake-xml-parser to 1.1.0 and apply output encoding on all user-supplied values before HTML rendering.

8. Verbose logging exposes internal stack traces to end users - Demo 121

MEDIUM

Tipo: fluidattacks | CVE: CVE-2025-99005 com.demo_fake-crypto-lib 1.2.3 | Prioridad: 0.01

Archivo: src/main/com.demo/fake-crypto-lib/demo_121.java

The logger library is configured to write full exception stack traces and internal class paths into HTTP responses in production.

[Fix] 1.2.5

9. Missing HTTP Strict-Transport-Security header - Demo 36

LOW

Tipo: fluidattacks | CVE: CVE-2025-99007 org.demo_fake-serializer 0.9.1 | Prioridad: 0.01

Archivo: src/main/org.demo/fake-serializer/demo_36.java

Responses from the insurance portal do not include the Strict-Transport-Security (HSTS) header.

DEMO_002_FakeShop_MR_ms_pedidos

Producto: Demo_DEMO002 | Vulnerabilidades: 9

1. Broken Authentication: Session tokens with insufficient entropy - Demo 117

CRITICAL

Tipo: fluidattacks | CVE: CVE-2025-99001 org.fake_demo-logger 1.8.5 | Prioridad: 0.01

Archivo: src/main/org.fake/demo-logger/demo_117.java

The session management module generates tokens with only 32 bits of entropy using a predictable PRNG seeded with system time.

[Fix] Upgrade com.fake:demo-session-manager to 3.0.0 or replace token generation with java.security.SecureRandom with at least 128-bit entropy.

2. SQL Injection via unparameterized dynamic query builder - Demo 2

HIGH

Tipo: fluidattacks | CVE: CVE-2025-99002 org.example_demo-http-client 2.1.0 | Prioridad: 0.01

Archivo: src/main/org.example/demo-http-client/demo_2.java

The user search endpoint concatenates user-supplied input directly into SQL statements without sanitization.

[Fix] Upgrade io.example:demo-auth-lib to 5.1.3 and replace all dynamic query construction with prepared statements.

3. Sensitive Data Exposure: Cryptographic keys stored in source code - Demo 32

HIGH

Tipo: fluidattacks | CVE: CVE-2025-99003 com.demo_example-cache 3.2.1 | Prioridad: 0.01

Archivo: src/main/com.demo/example-cache/demo_32.java

AES-128 encryption keys are hardcoded in the application source code and committed to the version control history.

[Fix] Rotate all exposed keys immediately. Move secrets to a vault solution (e.g. HashiCorp Vault or AWS Secrets Manager). Remove key material from git history.

4. Insecure Direct Object Reference in policy document download - Demo 122

HIGH

Tipo: fluidattacks | CVE: CVE-2025-99006 org.example_demo-http-client 2.1.0 | Prioridad: 0.01

Archivo: src/main/org.example/demo-http-client/demo_122.java

The policy download endpoint accepts a numeric document ID as a URL parameter without verifying ownership.

[Fix] Upgrade io.demo:fake-db-driver to 4.5.9 and implement resource-level authorization checks on every download request.

5. SQL Injection via unparameterized dynamic query builder - Demo 147

HIGH

Tipo: fluidattacks | CVE: CVE-2025-99002 com.example_fake-json-parser 3.0.1 | Prioridad: 0.01

Archivo: src/main/com.example/fake-json-parser/demo_147.java

The user search endpoint concatenates user-supplied input directly into SQL statements without sanitization.

[Fix] Upgrade io.example:demo-auth-lib to 5.1.3 and replace all dynamic query construction with prepared statements.

6. Open Redirect via unvalidated returnUrl query parameter - Demo 37

MEDIUM

Tipo: fluidattacks | CVE: CVE-2025-99008 com.demo_fake-crypto-lib 1.2.3 | Prioridad: 0.01

Archivo: src/main/com.demo/fake-crypto-lib/demo_37.java

The login flow in the test environment accepts an arbitrary returnUrl parameter and redirects the user post-authenticatio... without validating the destination domain, enabling phishing via trusted-doma...

[Fix] Upgrade org.example:demo-http-client to 2.1.4 and implement an allowlist of valid redirect destinations.

7. Cross-Site Scripting (Reflected) in error response body - Demo 62

MEDIUM

Tipo: fluidattacks | CVE: CVE-2025-99004 org.example_demo-http-client 2.1.0 | Prioridad: 0.01

Archivo: src/main/org.example/demo-http-client/demo_62.java

Error messages rendered by the XML parser module reflect unescaped request parameters into the HTML response.

[Fix] Upgrade org.demo:fake-xml-parser to 1.1.0 and apply output encoding on all user-supplied values before HTML rendering.

8. Verbose logging exposes internal stack traces to end users - Demo 92

MEDIUM

Tipo: fluidattacks | CVE: CVE-2025-99005 com.demo_example-cache 3.2.1 | Prioridad: 0.01

Archivo: src/main/com.demo/example-cache/demo_92.java

The logger library is configured to write full exception stack traces and internal class paths into HTTP responses in production.

[Fix] 3.3.0

9. Missing HTTP Strict-Transport-Security header - Demo 7

LOW

Tipo: fluidattacks | CVE: CVE-2025-99007 io.example_demo-auth-lib 5.1.0 | Prioridad: 0.01

Archivo: src/main/io.example/demo-auth-lib/demo_7.java

Responses from the insurance portal do not include the Strict-Transport-Security (HSTS) header.

[Fix] 5.1.3

DEMO_003_FakeLogistic_MR_ms_envios

Producto: Demo_DEMO003 | Vulnerabilidades: 9

1. Broken Authentication: Session tokens with insufficient entropy - Demo 88

CRITICAL

Tipo: fluidattacks | CVE: CVE-2025-99001 io.demo_fake-db-driver 4.5.2 | Prioridad: 0.01

Archivo: src/main/io.demo/fake-db-driver/demo_88.java

The session management module generates tokens with only 32 bits of entropy using a predictable PRNG seeded with system time.

[Fix] Upgrade com.fake:demo-session-manager to 3.0.0 or replace token generation with java.security.SecureRandom with at least 128-bit entropy.

2. Sensitive Data Exposure: Cryptographic keys stored in source code - Demo 3

HIGH

Tipo: fluidattacks | CVE: CVE-2025-99003 com.example_fake-json-parser 3.0.1 | Prioridad: 0.01

Archivo: src/main/com.example/fake-json-parser/demo_3.java

AES-128 encryption keys are hardcoded in the application source code and committed to the version control history.

[Fix] Rotate all exposed keys immediately. Move secrets to a vault solution (e.g. HashiCorp Vault or AWS Secrets Manager). Remove key material from git history.

3. Insecure Direct Object Reference in policy document download - Demo 93

HIGH

Tipo: fluidattacks | CVE: CVE-2025-99006 org.fake_demo-logger 1.8.5 | Prioridad: 0.01

Archivo: src/main/org.fake/demo-logger/demo_93.java

The policy download endpoint accepts a numeric document ID as a URL parameter without verifying ownership.

[Fix] Upgrade io.demo:fake-db-driver to 4.5.9 and implement resource-level authorization checks on every download request.

4. SQL Injection via unparameterized dynamic query builder - Demo 118

HIGH

Tipo: fluidattacks | CVE: CVE-2025-99002 com.example_demo-scheduler 2.0.0 | Prioridad: 0.01

Archivo: src/main/com.example/demo-scheduler/demo_118.java

The user search endpoint concatenates user-supplied input directly into SQL statements without sanitization.

[Fix] Upgrade io.example:demo-auth-lib to 5.1.3 and replace all dynamic query construction with prepared statements.

5. Sensitive Data Exposure: Cryptographic keys stored in source code - Demo 148

HIGH

Tipo: fluidattacks | CVE: CVE-2025-99003 io.demo_fake-db-driver 4.5.2 | Prioridad: 0.01

Archivo: src/main/io.demo/fake-db-driver/demo_148.java

AES-128 encryption keys are hardcoded in the application source code and committed to the version control history.

[Fix] Rotate all exposed keys immediately. Move secrets to a vault solution (e.g. HashiCorp Vault or AWS Secrets Manager). Remove key material from git history.

6. Open Redirect via unvalidated returnUrl query parameter - Demo 8

MEDIUM

Tipo: fluidattacks | CVE: CVE-2025-99008 com.demo_example-cache 3.2.1 | Prioridad: 0.01

Archivo: src/main/com.demo/example-cache/demo_8.java

The login flow in the test environment accepts an arbitrary returnUrl parameter and redirects the user post-authentication

[Fix] Upgrade org.example:demo-http-client to 2.1.4 and implement an allowlist of valid redirect destinations.

7. Cross-Site Scripting (Reflected) in error response body - Demo 33

MEDIUM

Tipo: fluidattacks | CVE: CVE-2025-99004 org.fake_demo-logger 1.8.5 | Prioridad: 0.01

Archivo: src/main/org.fake/demo-logger/demo_33.java

Error messages rendered by the XML parser module reflect unescaped request parameters into the HTML response.

[Fix] Upgrade org.demo:fake-xml-parser to 1.1.0 and apply output encoding on all user-supplied values before HTML rendering.

8. Verbose logging exposes internal stack traces to end users - Demo 63

● MEDIUM

Tipo: fluidattacks | CVE: CVE-2025-99005 com.example_fake-json-parser 3.0.1 | Prioridad: 0.01

Archivo: src/main/com.example/fake-json-parser/demo_63.java

The logger library is configured to write full exception stack traces and internal class paths into HTTP responses in production.

[Fix] 3.0.3**9. Missing HTTP Strict-Transport-Security header - Demo 123**

● LOW

Tipo: fluidattacks | CVE: CVE-2025-99007 com.example_fake-json-parser 3.0.1 | Prioridad: 0.01

Archivo: src/main/com.example/fake-json-parser/demo_123.java

Responses from the insurance portal do not include the Strict-Transport-Security (HSTS) header.

[Fix] 3.0.3**DEMO_004_FakeInsurance_MR_ms_polizas**

Producto: Demo_DEMO004 | Vulnerabilidades: 9

1. Broken Authentication: Session tokens with insufficient entropy - Demo 59

● CRITICAL

Tipo: fluidattacks | CVE: CVE-2025-99001 io.demo_fake-template-engine 6.3.0 | Prioridad: 0.01

Archivo: src/main/io.demo/fake-template-engine/demo_59.java

The session management module generates tokens with only 32 bits of entropy using a predictable PRNG seeded with system time.

[Fix] Upgrade com.fake:demo-session-manager to 3.0.0 or replace token generation with java.security.SecureRandom with at least 128-bit entropy.**2. Insecure Direct Object Reference in policy document download - Demo 64**

● HIGH

Tipo: fluidattacks | CVE: CVE-2025-99006 io.demo_fake-db-driver 4.5.2 | Prioridad: 0.01

Archivo: src/main/io.demo/fake-db-driver/demo_64.java

The policy download endpoint accepts a numeric document ID as a URL parameter without verifying ownership.

[Fix] Upgrade io.demo:fake-db-driver to 4.5.9 and implement resource-level authorization checks on every download request.**3. SQL Injection via unparameterized dynamic query builder - Demo 89**

● HIGH

Tipo: fluidattacks | CVE: CVE-2025-99002 org.demo_fake-xml-parser 1.0.0 | Prioridad: 0.01

Archivo: src/main/org.demo/fake-xml-parser/demo_89.java

The user search endpoint concatenates user-supplied input directly into SQL statements without sanitization.

[Fix] Upgrade io.example:demo-auth-lib to 5.1.3 and replace all dynamic query construction with prepared statements.**4. Sensitive Data Exposure: Cryptographic keys stored in source code - Demo 119**

● HIGH

Tipo: fluidattacks | CVE: CVE-2025-99003 io.demo_fake-template-engine 6.3.0 | Prioridad: 0.01

Archivo: src/main/io.demo/fake-template-engine/demo_119.java

AES-128 encryption keys are hardcoded in the application source code and committed to the version control history.

[Fix] Rotate all exposed keys immediately. Move secrets to a vault solution (e.g. HashiCorp Vault or AWS Secrets Manager). Remove key material from git history.

5. Cross-Site Scripting (Reflected) in error response body - Demo 4

● MEDIUM

Tipo: fluidattacks | CVE: CVE-2025-99004 io.demo_fake-db-driver 4.5.2 | Prioridad: 0.01

Archivo: src/main/io.demo/fake-db-driver/demo_4.java

*Error messages rendered by the XML parser module reflect unescaped request parameters into the HTML response.***[Fix]** Upgrade org.demo:fake-xml-parser to 1.1.0 and apply output encoding on all user-supplied values before HTML rendering.**6. Verbose logging exposes internal stack traces to end users - Demo 34**

● MEDIUM

Tipo: fluidattacks | CVE: CVE-2025-99005 com.example_demo-scheduler 2.0.0 | Prioridad: 0.01

Archivo: src/main/com.example/demo-scheduler/demo_34.java

*The logger library is configured to write full exception stack traces and internal class paths into HTTP responses in... production.***[Fix]** 2.0.2**7. Open Redirect via unvalidated returnUrl query parameter - Demo 124**

● MEDIUM

Tipo: fluidattacks | CVE: CVE-2025-99008 io.demo_fake-db-driver 4.5.2 | Prioridad: 0.01

Archivo: src/main/io.demo/fake-db-driver/demo_124.java

*The login flow in the test environment accepts an arbitrary returnUrl parameter and redirects the user post-authentication without validating the destination domain, enabling phishing via trusted-doma...***[Fix]** Upgrade org.example:demo-http-client to 2.1.4 and implement an allowlist of valid redirect destinations.**8. Cross-Site Scripting (Reflected) in error response body - Demo 149**

● MEDIUM

Tipo: fluidattacks | CVE: CVE-2025-99004 org.demo_fake-xml-parser 1.0.0 | Prioridad: 0.01

Archivo: src/main/org.demo/fake-xml-parser/demo_149.java

*Error messages rendered by the XML parser module reflect unescaped request parameters into the HTML response.***[Fix]** Upgrade org.demo:fake-xml-parser to 1.1.0 and apply output encoding on all user-supplied values before HTML rendering.**9. Missing HTTP Strict-Transport-Security header - Demo 94**

● LOW

Tipo: fluidattacks | CVE: CVE-2025-99007 com.example_demo-scheduler 2.0.0 | Prioridad: 0.01

Archivo: src/main/com.example/demo-scheduler/demo_94.java

*Responses from the insurance portal do not include the Strict-Transport-Security (HSTS) header.***[Fix]** 2.0.2**> Servicios de Test****DEMO_002_FakeShop_TEST_ms_pedidos_test**

Producto: Demo_DEMO002 | Vulnerabilidades: 9

1. Broken Authentication: Session tokens with insufficient entropy - Demo 30

● CRITICAL

Tipo: fluidattacks | CVE: CVE-2025-99001 com.fake_demo-session-manager 2.3.4 | Prioridad: 0.01

Archivo: src/main/com.fake/demo-session-manager/demo_30.java

*The session management module generates tokens with only 32 bits of entropy using a predictable PRNG seeded with system time.***[Fix]** Upgrade com.fake:demo-session-manager to 3.0.0 or replace token generation with java.security.SecureRandom with at least 128-bit entropy.

2. Insecure Direct Object Reference in policy document download - Demo 35

HIGH

Tipo: fluidattacks | CVE: CVE-2025-99006 io.demo_fake-template-engine 6.3.0 | Prioridad: 0.01

Archivo: src/main/io.demo/fake-template-engine/demo_35.java

The policy download endpoint accepts a numeric document ID as a URL parameter without verifying ownership.

[Fix] Upgrade io.demo:fake-db-driver to 4.5.9 and implement resource-level authorization checks on every download request.

3. SQL Injection via unparameterized dynamic query builder - Demo 60

HIGH

Tipo: fluidattacks | CVE: CVE-2025-99002 org.demo_fake-serializer 0.9.1 | Prioridad: 0.01

Archivo: src/main/org.demo/fake-serializer/demo_60.java

The user search endpoint concatenates user-supplied input directly into SQL statements without sanitization.

[Fix] Upgrade io.example:demo-auth-lib to 5.1.3 and replace all dynamic query construction with prepared statements.

4. Sensitive Data Exposure: Cryptographic keys stored in source code - Demo 90

HIGH

Tipo: fluidattacks | CVE: CVE-2025-99003 com.fake_demo-session-manager 2.3.4 | Prioridad: 0.01

Archivo: src/main/com.fake/demo-session-manager/demo_90.java

AES-128 encryption keys are hardcoded in the application source code and committed to the version control history.

[Fix] Rotate all exposed keys immediately. Move secrets to a vault solution (e.g. HashiCorp Vault or AWS Secrets Manager). Remove key material from git history.

5. Verbose logging exposes internal stack traces to end users - Demo 5

MEDIUM

Tipo: fluidattacks | CVE: CVE-2025-99005 org.demo_fake-xml-parser 1.0.0 | Prioridad: 0.01

Archivo: src/main/org.demo/fake-xml-parser/demo_5.java

The logger library is configured to write full exception stack traces and internal class paths into HTTP responses in production.

[Fix] 1.1.0

6. Open Redirect via unvalidated returnUrl query parameter - Demo 95

MEDIUM

Tipo: fluidattacks | CVE: CVE-2025-99008 io.demo_fake-template-engine 6.3.0 | Prioridad: 0.01

Archivo: src/main/io.demo/fake-template-engine/demo_95.java

The login flow in the test environment accepts an arbitrary returnUrl parameter and redirects the user post-authentication

[Fix] Upgrade org.example:demo-http-client to 2.1.4 and implement an allowlist of valid redirect destinations.

7. Cross-Site Scripting (Reflected) in error response body - Demo 120

MEDIUM

Tipo: fluidattacks | CVE: CVE-2025-99004 org.demo_fake-serializer 0.9.1 | Prioridad: 0.01

Archivo: src/main/org.demo/fake-serializer/demo_120.java

Error messages rendered by the XML parser module reflect unescaped request parameters into the HTML response.

[Fix] Upgrade org.demo:fake-xml-parser to 1.1.0 and apply output encoding on all user-supplied values before HTML rendering.

8. Verbose logging exposes internal stack traces to end users - Demo 150

MEDIUM

Tipo: fluidattacks | CVE: CVE-2025-99005 com.fake_demo-session-manager 2.3.4 | Prioridad: 0.01

Archivo: src/main/com.fake/demo-session-manager/demo_150.java

The logger library is configured to write full exception stack traces and internal class paths into HTTP responses in production.

9. Missing HTTP Strict-Transport-Security header - Demo 65

LOW

Tipo: fluidattacks | CVE: CVE-2025-99007 org.demo_fake-xml-parser 1.0.0 | Prioridad: 0.01

Archivo: src/main/org.demo/fake-xml-parser/demo_65.java

Responses from the insurance portal do not include the Strict-Transport-Security (HSTS) header.

[Fix] 1.1.0

4.2 C2C (Continuous Compliance)

Vulnerabilidades de configuración y cumplimiento en recursos AWS.

Total vulnerabilidades: 25 | Servicios afectados: 5

> Servicios Productivos

DEMO_001_FakeBank_MR_ms_cuentas

Producto: Demo_DEMO001 | Vulnerabilidades: 5

1. AWS S3 bucket with public read access and no encryption at rest - Demo 96

CRITICAL

Tipo: c2c | CVE: CVE-2025-99009 org.demo_fake-serializer 0.9.1 | Prioridad: 0.01

Archivo: src/main/org.demo/fake-serializer/demo_96.java

The S3 bucket used by the orders service for storing order attachments is configured with ACL public-read and has server-side encryption disabled.

[Fix] Enable SSE-S3 or SSE-KMS encryption. Remove public-read ACL and enforce bucket policy to deny public access. Upgrade cache lib to 3.3.0.

2. IAM role with wildcard action allows privilege escalation - Demo 126

HIGH

Tipo: c2c | CVE: CVE-2025-99010 com.fake_demo-session-manager 2.3.4 | Prioridad: 0.01

Archivo: src/main/com.fake/demo-session-manager/demo_126.java

An IAM role attached to the orders microservice grants "Action: *" on "Resource: *" without condition keys.

[Fix] Restrict IAM role to least-privilege actions required by the service. Apply permission boundaries.

3. CloudTrail logging disabled for management events in region us-east-1 - Demo 11

MEDIUM

Tipo: c2c | CVE: CVE-2025-99011 io.demo_fake-template-engine 6.3.0 | Prioridad: 0.01

Archivo: src/main/io.demo/fake-template-engine/demo_11.java

AWS CloudTrail is not enabled for management event logging in the us-east-1 region.

[Fix] 6.3.2

4. Security group allows unrestricted inbound SSH access from 0.0.0.0/0 - Demo 41

MEDIUM

Tipo: c2c | CVE: CVE-2025-99012 org.demo_fake-xml-parser 1.0.0 | Prioridad: 0.01

Archivo: src/main/org.demo/fake-xml-parser/demo_41.java

The EC2 security group associated with the insurance service allows inbound TCP port 22 (SSH) from all IPv4 addresses.

[Fix] Restrict SSH access to a bastion host IP range or use AWS Systems Manager Session Manager to eliminate SSH exposure entirely.

5. RDS instance with automated backups disabled - Demo 71

● LOW

Tipo: c2c | CVE: CVE-2025-99013 io.demo_fake-template-engine 6.3.0 | Prioridad: 0.01

Archivo: src/main/io.demo/fake-template-engine/demo_71.java

*The RDS database instance for the insurance service has automated backups disabled.***[Fix]** Enable automated backups with a retention period of at least 7 days. Upgrade template engine to 6.3.2.**DEMO_002_FakeShop_MR_ms_pedidos**

Producto: Demo_DEMO002 | Vulnerabilidades: 5

1. AWS S3 bucket with public read access and no encryption at rest - Demo 67

● CRITICAL

Tipo: c2c | CVE: CVE-2025-99009 io.example_demo-auth-lib 5.1.0 | Prioridad: 0.01

Archivo: src/main/io.example/demo-auth-lib/demo_67.java

*The S3 bucket used by the orders service for storing order attachments is configured with ACL public-read and has server-side encryption disabled.***[Fix]** Enable SSE-S3 or SSE-KMS encryption. Remove public-read ACL and enforce bucket policy to deny public access. Upgrade cache lib to 3.3.0.**2. IAM role with wildcard action allows privilege escalation - Demo 97**

● HIGH

Tipo: c2c | CVE: CVE-2025-99010 com.demo_fake-crypto-lib 1.2.3 | Prioridad: 0.01

Archivo: src/main/com.demo/fake-crypto-lib/demo_97.java

*An IAM role attached to the orders microservice grants "Action: *" on "Resource: *" without condition keys.***[Fix]** Restrict IAM role to least-privilege actions required by the service. Apply permission boundaries.**3. Security group allows unrestricted inbound SSH access from 0.0.0.0/0 - Demo 12**

● MEDIUM

Tipo: c2c | CVE: CVE-2025-99012 org.demo_fake-serializer 0.9.1 | Prioridad: 0.01

Archivo: src/main/org.demo/fake-serializer/demo_12.java

*The EC2 security group associated with the insurance service allows inbound TCP port 22 (SSH) from all IPv4 addresses.***[Fix]** Restrict SSH access to a bastion host IP range or use AWS Systems Manager Session Manager to eliminate SSH exposure entirely.**4. CloudTrail logging disabled for management events in region us-east-1 - Demo 127**

● MEDIUM

Tipo: c2c | CVE: CVE-2025-99011 io.example_demo-auth-lib 5.1.0 | Prioridad: 0.01

Archivo: src/main/io.example/demo-auth-lib/demo_127.java

*AWS CloudTrail is not enabled for management event logging in the us-east-1 region.***[Fix]** 5.1.3**5. RDS instance with automated backups disabled - Demo 42**

● LOW

Tipo: c2c | CVE: CVE-2025-99013 com.fake_demo-session-manager 2.3.4 | Prioridad: 0.01

Archivo: src/main/com.fake/demo-session-manager/demo_42.java

*The RDS database instance for the insurance service has automated backups disabled.***[Fix]** Enable automated backups with a retention period of at least 7 days. Upgrade template engine to 6.3.2.

DEMO_003_FakeLogistic_MR_ms_envios

Producto: Demo_DEMO003 | Vulnerabilidades: 5

1. AWS S3 bucket with public read access and no encryption at rest - Demo 38

● CRITICAL

Tipo: c2c | CVE: CVE-2025-99009 org.example_demo-http-client 2.1.0 | Prioridad: 0.01

Archivo: src/main/org.example/demo-http-client/demo_38.java

The S3 bucket used by the orders service for storing order attachments is configured with ACL public-read and has server-side encryption disabled.

[Fix] Enable SSE-S3 or SSE-KMS encryption. Remove public-read ACL and enforce bucket policy to deny public access. Upgrade cache lib to 3.3.0.

2. IAM role with wildcard action allows privilege escalation - Demo 68

● HIGH

Tipo: c2c | CVE: CVE-2025-99010 com.demo_example-cache 3.2.1 | Prioridad: 0.01

Archivo: src/main/com.demo/example-cache/demo_68.java

An IAM role attached to the orders microservice grants "Action: *" on "Resource: *" without condition keys.

[Fix] Restrict IAM role to least-privilege actions required by the service. Apply permission boundaries.

3. CloudTrail logging disabled for management events in region us-east-1 - Demo 98

● MEDIUM

Tipo: c2c | CVE: CVE-2025-99011 org.example_demo-http-client 2.1.0 | Prioridad: 0.01

Archivo: src/main/org.example/demo-http-client/demo_98.java

AWS CloudTrail is not enabled for management event logging in the us-east-1 region.

[Fix] 2.1.4

4. Security group allows unrestricted inbound SSH access from 0.0.0.0/0 - Demo 128

● MEDIUM

Tipo: c2c | CVE: CVE-2025-99012 com.demo_example-cache 3.2.1 | Prioridad: 0.01

Archivo: src/main/com.demo/example-cache/demo_128.java

The EC2 security group associated with the insurance service allows inbound TCP port 22 (SSH) from all IPv4 addresses.

[Fix] Restrict SSH access to a bastion host IP range or use AWS Systems Manager Session Manager to eliminate SSH exposure entirely.

5. RDS instance with automated backups disabled - Demo 13

● LOW

Tipo: c2c | CVE: CVE-2025-99013 com.demo_fake-crypto-lib 1.2.3 | Prioridad: 0.01

Archivo: src/main/com.demo/fake-crypto-lib/demo_13.java

The RDS database instance for the insurance service has automated backups disabled.

[Fix] Enable automated backups with a retention period of at least 7 days. Upgrade template engine to 6.3.2.

DEMO_004_FakeInsurance_MR_ms_polizas

Producto: Demo_DEMO004 | Vulnerabilidades: 5

1. AWS S3 bucket with public read access and no encryption at rest - Demo 9

● CRITICAL

Tipo: c2c | CVE: CVE-2025-99009 org.fake_demo-logger 1.8.5 | Prioridad: 0.01

Archivo: src/main/org.fake/demo-logger/demo_9.java

The S3 bucket used by the orders service for storing order attachments is configured with ACL public-read and has server-side encryption disabled.

[Fix] Enable SSE-S3 or SSE-KMS encryption. Remove public-read ACL and enforce bucket policy to deny public access. Upgrade cache lib to 3.3.0.

2. IAM role with wildcard action allows privilege escalation - Demo 39**HIGH**

Tipo: c2c | CVE: CVE-2025-99010 com.example_fake-json-parser 3.0.1 | Prioridad: 0.01

Archivo: src/main/com.example/fake-json-parser/demo_39.java

*An IAM role attached to the orders microservice grants "Action: *" on "Resource: *" without condition keys.***[Fix]** Restrict IAM role to least-privilege actions required by the service. Apply permission boundaries.**3. CloudTrail logging disabled for management events in region us-east-1 - Demo 69****MEDIUM**

Tipo: c2c | CVE: CVE-2025-99011 org.fake_demo-logger 1.8.5 | Prioridad: 0.01

Archivo: src/main/org.fake/demo-logger/demo_69.java

*AWS CloudTrail is not enabled for management event logging in the us-east-1 region.***4. Security group allows unrestricted inbound SSH access from 0.0.0.0/0 - Demo 99****MEDIUM**

Tipo: c2c | CVE: CVE-2025-99012 com.example_fake-json-parser 3.0.1 | Prioridad: 0.01

Archivo: src/main/com.example/fake-json-parser/demo_99.java

*The EC2 security group associated with the insurance service allows inbound TCP port 22 (SSH) from all IPv4 addresses.***[Fix]** Restrict SSH access to a bastion host IP range or use AWS Systems Manager Session Manager to eliminate SSH exposure entirely.**5. RDS instance with automated backups disabled - Demo 129****LOW**

Tipo: c2c | CVE: CVE-2025-99013 org.fake_demo-logger 1.8.5 | Prioridad: 0.01

Archivo: src/main/org.fake/demo-logger/demo_129.java

*The RDS database instance for the insurance service has automated backups disabled.***[Fix]** Enable automated backups with a retention period of at least 7 days. Upgrade template engine to 6.3.2.**> Servicios de Test****DEMO_002_FakeShop_TEST_ms_pedidos_test**

Producto: Demo_DEMO002 | Vulnerabilidades: 5

1. AWS S3 bucket with public read access and no encryption at rest - Demo 125**CRITICAL**

Tipo: c2c | CVE: CVE-2025-99009 org.demo_fake-xml-parser 1.0.0 | Prioridad: 0.01

Archivo: src/main/org.demo/fake-xml-parser/demo_125.java

*The S3 bucket used by the orders service for storing order attachments is configured with ACL public-read and has server-side encryption disabled.***[Fix]** Enable SSE-S3 or SSE-KMS encryption. Remove public-read ACL and enforce bucket policy to deny public access. Upgrade cache lib to 3.3.0.**2. IAM role with wildcard action allows privilege escalation - Demo 10****HIGH**

Tipo: c2c | CVE: CVE-2025-99010 com.example_demo-scheduler 2.0.0 | Prioridad: 0.01

Archivo: src/main/com.example/demo-scheduler/demo_10.java

*An IAM role attached to the orders microservice grants "Action: *" on "Resource: *" without condition keys.***[Fix]** Restrict IAM role to least-privilege actions required by the service. Apply permission boundaries.

3. CloudTrail logging disabled for management events in region us-east-1 - Demo 40

● MEDIUM

Tipo: c2c | CVE: CVE-2025-99011 io.demo_fake-db-driver 4.5.2 | Prioridad: 0.01

Archivo: src/main/io.demo/fake-db-driver/demo_40.java

*AWS CloudTrail is not enabled for management event logging in the us-east-1 region.***[Fix]** 4.5.9**4. Security group allows unrestricted inbound SSH access from 0.0.0.0/0 - Demo 70**

● MEDIUM

Tipo: c2c | CVE: CVE-2025-99012 com.example_demo-scheduler 2.0.0 | Prioridad: 0.01

Archivo: src/main/com.example/demo-scheduler/demo_70.java

*The EC2 security group associated with the insurance service allows inbound TCP port 22 (SSH) from all IPv4 addresses.***[Fix]** Restrict SSH access to a bastion host IP range or use AWS Systems Manager Session Manager to eliminate SSH exposure entirely.**5. RDS instance with automated backups disabled - Demo 100**

● LOW

Tipo: c2c | CVE: CVE-2025-99013 io.demo_fake-db-driver 4.5.2 | Prioridad: 0.01

Archivo: src/main/io.demo/fake-db-driver/demo_100.java

*The RDS database instance for the insurance service has automated backups disabled.***[Fix]** Enable automated backups with a retention period of at least 7 days. Upgrade template engine to 6.3.2.**4.3 IAC / NGC / NG DEP**

Vulnerabilidades de dependencias, contenedores, infraestructura como código y listas negras.

Total vulnerabilidades: 80 | Servicios afectados: 5

> Servicios Productivos**DEMO_001_FakeBank_MR_ms_cuentas**

Producto: Demo_DEMO001 | Vulnerabilidades: 16

1. DB Driver: Remote code execution via deserialization of untrusted data - Demo 46

● CRITICAL

Tipo: engine_dependencies | CVE: CVE-2025-99017 com.example_demo-scheduler 2.0.0 | Prioridad: 0.01

Archivo: src/main/com.example/demo-scheduler/demo_46.java

*io.demo:fake-db-driver versions before 4.5.9 deserialize server-provided responses without type validation.***[Fix]** Upgrade io.demo:fake-db-driver to 4.5.9 immediately.**2. Crypto Lib: Weak RSA key generation due to biased PRNG - Demo 16**

● HIGH

Tipo: engine_dependencies | CVE: CVE-2025-99016 io.demo_fake-db-driver 4.5.2 | Prioridad: 0.01

Archivo: src/main/io.demo/fake-db-driver/demo_16.java

*com.demo:fake-crypto-lib prior to 1.2.5 uses a PRNG with a measurable statistical bias when generating RSA prime candidates.***[Fix]** Upgrade com.demo:fake-crypto-lib to 1.2.5.

3. Terraform: S3 backend state file has no encryption or access logging - Demo 26

● HIGH

Tipo: engine_iac | CVE: CVE-2025-99025 org.example_demo-http-client 2.1.0 | Prioridad: 0.01

Archivo: src/main/org.example/demo-http-client/demo_26.java

The Terraform remote state backend S3 bucket is configured without server-side encryption and without access logging.

[Fix] Enable SSE-KMS on the Terraform state bucket and configure S3 access logging to a separate audit bucket.

4. Container image running as root user without read-only filesystem - Demo 51

● HIGH

Tipo: engine_container | CVE: CVE-2025-99022 com.example_fake-json-parser 3.0.1 | Prioridad: 0.01

Archivo: src/main/com.example/fake-json-parser/demo_51.java

The Docker image for the accounts service runs processes as root (UID 0) and mounts the application volume as read-write.

[Fix] Define a non-root USER in the Dockerfile and set the root filesystem to read-only using `securityContext.readOnlyRootFilesystem: true`.

5. HTTP Client: Server-Side Request Forgery via malformed redirect handling - Demo 101

● HIGH

Tipo: engine_dependencies | CVE: CVE-2025-99014 org.demo_fake-xml-parser 1.0.0 | Prioridad: 0.01

Archivo: src/main/org.demo/fake-xml-parser/demo_101.java

org.example_demo-http-client versions below 2.1.4 do not validate redirect destinations when following 3xx responses.

[Fix] Upgrade org.example_demo-http-client to 2.1.4.

6. Blacklisted dependency: known malicious package in transitive graph - Demo 116

● HIGH

Tipo: black_list; engine_dependencies | CVE: CVE-2025-99027 com.demo_example-cache 3.2.1 | Prioridad: 0.01

Archivo: src/main/com.demo/example-cache/demo_116.java

A transitive dependency of the orders service pulls in org.fake_demo-serializer 0.9.1, which appears on the internal security blacklist following the discovery of obfuscated exfiltration code in a pre-release version.

[Fix] Remove org.fake_demo-serializer from the dependency graph. Replace with a vetted serialization alternative and verify no other transitive paths re-introduce the package.

7. Template Engine: Server-side template injection via user-controlled input - Demo 21

● MEDIUM

Tipo: engine_dependencies | CVE: CVE-2025-99021 org.fake_demo-logger 1.8.5 | Prioridad: 0.01

Archivo: src/main/org.fake/demo-logger/demo_21.java

io.demo_fake-template-engine 6.3.0 evaluates template expressions found in user input without sandboxing.

[Fix] Upgrade io.demo_fake-template-engine to 6.3.2 and always sanitize input before passing it to the template rendering context.

8. Kubernetes RBAC: ClusterRole binds wildcard verbs to core API group - Demo 56

● MEDIUM

Tipo: engine_iac | CVE: CVE-2025-99026 com.demo_example-cache 3.2.1 | Prioridad: 0.01

Archivo: src/main/com.demo/example-cache/demo_56.java

A ClusterRole definition in the Helm chart grants [""] verbs on core API resources including pods, secrets, and configmaps.*

[Fix] Replace wildcard verbs with explicit minimal verb sets. Separate read and write roles. Upgrade scheduler to 2.0.2 to patch related scheduling flaw.

9. Auth Lib: JWT signature verification bypass with algorithm confusion - Demo 76

● MEDIUM

Tipo: engine_dependencies | CVE: CVE-2025-99018 io.demo_fake-db-driver 4.5.2 | Prioridad: 0.01

Archivo: src/main/io.demo/fake-db-driver/demo_76.java

*io.example:demo-auth-lib before 5.1.3 accepts JWTs with the "none" algorithm if the header algorithm field is set to "None" (mixed case).***[Fix]** Upgrade io.example:demo-auth-lib to 5.1.3 and explicitly reject the "none" algorithm in the JWT validation configuration.**10. Container image based on deprecated base OS with unpatched CVEs - Demo 81**

● MEDIUM

Tipo: engine_container | CVE: CVE-2025-99023 org.fake_demo-logger 1.8.5 | Prioridad: 0.01

Archivo: src/main/org.fake/demo-logger/demo_81.java

*The orders service container image is built on a base OS image that reached end-of-life and no longer receives security... patches.***[Fix]** Rebuild image using a maintained base image (e.g. alpine:3.19 or debian:bookworm-slim). Pin base image digest to prevent supply-chain substitution.**11. JSON Parser: Uncontrolled resource consumption via deeply nested input - Demo 131**

● MEDIUM

Tipo: engine_dependencies | CVE: CVE-2025-99015 io.demo_fake-template-engine 6.3.0 | Prioridad: 0.01

Archivo: src/main/io.demo/fake-template-engine/demo_131.java

*com.example:fake-json-parser versions before 3.0.3 do not impose limits on object nesting depth.***[Fix]** Upgrade com.example:fake-json-parser to 3.0.3.**12. XML Parser: Billion laughs XML entity expansion attack - Demo 136**

● MEDIUM

Tipo: engine_dependencies | CVE: CVE-2025-99020 io.demo_fake-db-driver 4.5.2 | Prioridad: 0.01

Archivo: src/main/io.demo/fake-db-driver/demo_136.java

*org.demo:fake-xml-parser versions before 1.1.0 do not set limits on XML entity expansion.***[Fix]** Upgrade org.demo:fake-xml-parser to 1.1.0.**13. Scheduler: Denial of service via malformed cron expression - Demo 106**

● LOW

Tipo: engine_dependencies | CVE: CVE-2025-99019 com.example_demo-scheduler 2.0.0 | Prioridad: 0.01

Archivo: src/main/com.example/demo-scheduler/demo_106.java

*com.example:demo-scheduler version 2.0.0 does not validate cron expressions before parsing.***[Fix]** Upgrade com.example:demo-scheduler to 2.0.2.**14. Secrets mounted as environment variables in container spec - Demo 111**

● LOW

Tipo: engine_container | CVE: CVE-2025-99024 com.example_fake-json-parser 3.0.1 | Prioridad: 0.01

Archivo: src/main/com.example/fake-json-parser/demo_111.java

*Database credentials and API keys are injected as environment variables in the Kubernetes pod specification using plain-text values.***[Fix]** 3.0.3**15. Terraform module lacks required_providers version constraints - Demo 86**

● INFO

Tipo: engine_iac | Prioridad: 0.00

Archivo: src/main/org.example/demo-http-client/demo_86.java

*Several Terraform modules declare providers without pinning to a specific version range.***[Fix]** 2.1.4

16. Container image has no defined HEALTHCHECK instruction - Demo 141

● INFO

Tipo: engine_container | Prioridad: 0.00

Archivo: src/main/org.fake/demo-logger/demo_141.java

*The insurance service Dockerfile does not define a HEALTHCHECK instruction.***[Fix]** Add HEALTHCHECK INTERVAL=30s TIMEOUT=5s CMD curl -f http://localhost:8080/actuator/health || exit 1 to the Dockerfile.**DEMO_002_FakeShop_MR_ms_pedidos**

Producto: Demo_DEMO002 | Vulnerabilidades: 16

1. DB Driver: Remote code execution via deserialization of untrusted data - Demo 17

● CRITICAL

Tipo: engine_dependencies | CVE: CVE-2025-99017 org.demo_fake-xml-parser 1.0.0 | Prioridad: 0.01

Archivo: src/main/org.demo/fake-xml-parser/demo_17.java

*io.demo:fake-db-driver versions before 4.5.9 deserialize server-provided responses without type validation.***[Fix]** Upgrade io.demo:fake-db-driver to 4.5.9 immediately.**2. Container image running as root user without read-only filesystem - Demo 22**

● HIGH

Tipo: engine_container | CVE: CVE-2025-99022 com.example_demo-scheduler 2.0.0 | Prioridad: 0.01

Archivo: src/main/com.example/demo-scheduler/demo_22.java

*The Docker image for the accounts service runs processes as root (UID 0) and mounts the application volume as read-write.***[Fix]** Define a non-root USER in the Dockerfile and set the root filesystem to read-only using securityContext.readOnlyRootFilesystem: true.**3. HTTP Client: Server-Side Request Forgery via malformed redirect handling - Demo 72**

● HIGH

Tipo: engine_dependencies | CVE: CVE-2025-99014 org.demo_fake-serializer 0.9.1 | Prioridad: 0.01

Archivo: src/main/org.demo/fake-serializer/demo_72.java

*org.example:demo-http-client versions below 2.1.4 do not validate redirect destinations when following 3xx responses.***[Fix]** Upgrade org.example:demo-http-client to 2.1.4.**4. Blacklisted dependency: known malicious package in transitive graph - Demo 87**

● HIGH

Tipo: black_list; engine_dependencies | CVE: CVE-2025-99027 com.example_fake-json-parser 3.0.1 | Prioridad: 0.01

Archivo: src/main/com.example/fake-json-parser/demo_87.java

*A transitive dependency of the orders service pulls in org.fake:demo-serializer 0.9.1, which appears on the internal security blacklist following the discovery of obfuscated exfiltration code in a pre...***[Fix]** Remove org.fake:demo-serializer from the dependency graph. Replace with a vetted serialization alternative and verify no other transitive paths re-introduce the package.**5. Crypto Lib: Weak RSA key generation due to biased PRNG - Demo 132**

● HIGH

Tipo: engine_dependencies | CVE: CVE-2025-99016 org.demo_fake-serializer 0.9.1 | Prioridad: 0.01

Archivo: src/main/org.demo/fake-serializer/demo_132.java

*com.demo:fake-crypto-lib prior to 1.2.5 uses a PRNG with a measurable statistical bias when generating RSA prime candidates.***[Fix]** Upgrade com.demo:fake-crypto-lib to 1.2.5.

6. Terraform: S3 backend state file has no encryption or access logging - Demo 142

● HIGH

Tipo: engine_iac | CVE: CVE-2025-99025 com.example_demo-scheduler 2.0.0 | Prioridad: 0.01

Archivo: src/main/com.example/demo-scheduler/demo_142.java

*The Terraform remote state backend S3 bucket is configured without server-side encryption and without access logging.***[Fix]** Enable SSE-KMS on the Terraform state bucket and configure S3 access logging to a separate audit bucket.**7. Kubernetes RBAC: ClusterRole binds wildcard verbs to core API group - Demo 27**

● MEDIUM

Tipo: engine_iac | CVE: CVE-2025-99026 com.example_fake-json-parser 3.0.1 | Prioridad: 0.01

Archivo: src/main/com.example/fake-json-parser/demo_27.java

A ClusterRole definition in the Helm chart grants [""] verbs on core API resources including pods, secrets, and... configmaps.***[Fix]** Replace wildcard verbs with explicit minimal verb sets. Separate read and write roles. Upgrade scheduler to 2.0.2 to patch related scheduling flaw.**8. Auth Lib: JWT signature verification bypass with algorithm confusion - Demo 47**

● MEDIUM

Tipo: engine_dependencies | CVE: CVE-2025-99018 io.demo_fake-template-engine 6.3.0 | Prioridad: 0.01

Archivo: src/main/io.demo/fake-template-engine/demo_47.java

*io.example:demo-auth-lib before 5.1.3 accepts JWTs with the "none" algorithm if the header algorithm field is set to "None" (mixed case).***[Fix]** Upgrade io.example:demo-auth-lib to 5.1.3 and explicitly reject the "none" algorithm in the JWT validation configuration.**9. Container image based on deprecated base OS with unpatched CVEs - Demo 52**

● MEDIUM

Tipo: engine_container | CVE: CVE-2025-99023 io.demo_fake-db-driver 4.5.2 | Prioridad: 0.01

Archivo: src/main/io.demo/fake-db-driver/demo_52.java

*The orders service container image is built on a base OS image that reached end-of-life and no longer receives security patches.***[Fix]** Rebuild image using a maintained base image (e.g. alpine:3.19 or debian:bookworm-slim). Pin base image digest to prevent supply-chain substitution.**10. JSON Parser: Uncontrolled resource consumption via deeply nested input - Demo 102**

● MEDIUM

Tipo: engine_dependencies | CVE: CVE-2025-99015 com.fake_demo-session-manager 2.3.4 | Prioridad: 0.01

Archivo: src/main/com.fake/demo-session-manager/demo_102.java

*com.example:fake-json-parser versions before 3.0.3 do not impose limits on object nesting depth.***[Fix]** Upgrade com.example:fake-json-parser to 3.0.3.**11. XML Parser: Billion laughs XML entity expansion attack - Demo 107**

● MEDIUM

Tipo: engine_dependencies | CVE: CVE-2025-99020 io.demo_fake-template-engine 6.3.0 | Prioridad: 0.01

Archivo: src/main/io.demo/fake-template-engine/demo_107.java

*org.demo:fake-xml-parser versions before 1.1.0 do not set limits on XML entity expansion.***[Fix]** Upgrade org.demo:fake-xml-parser to 1.1.0.

12. Template Engine: Server-side template injection via user-controlled input - Demo 137

● MEDIUM

Tipo: engine_dependencies | CVE: CVE-2025-99021 org.demo_fake-xml-parser 1.0.0 | Prioridad: 0.01

Archivo: src/main/org.demo/fake-xml-parser/demo_137.java

*io.demo:fake-template-engine 6.3.0 evaluates template expressions found in user input without sandboxing.***[Fix]** Upgrade io.demo:fake-template-engine to 6.3.2 and always sanitize input before passing it to the template rendering context.**13. Scheduler: Denial of service via malformed cron expression - Demo 77**

● LOW

Tipo: engine_dependencies | CVE: CVE-2025-99019 org.demo_fake-xml-parser 1.0.0 | Prioridad: 0.01

Archivo: src/main/org.demo/fake-xml-parser/demo_77.java

*com.example:demo-scheduler version 2.0.0 does not validate cron expressions before parsing.***[Fix]** Upgrade com.example:demo-scheduler to 2.0.2.**14. Secrets mounted as environment variables in container spec - Demo 82**

● LOW

Tipo: engine_container | CVE: CVE-2025-99024 com.example_demo-scheduler 2.0.0 | Prioridad: 0.01

Archivo: src/main/com.example/demo-scheduler/demo_82.java

*Database credentials and API keys are injected as environment variables in the Kubernetes pod specification using plain-text values.***[Fix]** 2.0.2**15. Terraform module lacks required_providers version constraints - Demo 57**

● INFO

Tipo: engine_iac | Prioridad: 0.00

Archivo: src/main/org.fake/demo-logger/demo_57.java

*Several Terraform modules declare providers without pinning to a specific version range.***16. Container image has no defined HEALTHCHECK instruction - Demo 112**

● INFO

Tipo: engine_container | Prioridad: 0.00

Archivo: src/main/io.demo/fake-db-driver/demo_112.java

*The insurance service Dockerfile does not define a HEALTHCHECK instruction.***[Fix]** Add HEALTHCHECK INTERVAL=30s TIMEOUT=5s CMD curl -f http://localhost:8080/actuator/health || exit 1 to the Dockerfile.**DEMO_003_FakeLogistic_MR_ms_envios**

Producto: Demo_DEMO003 | Vulnerabilidades: 16

1. DB Driver: Remote code execution via deserialization of untrusted data - Demo 133

● CRITICAL

Tipo: engine_dependencies | CVE: CVE-2025-99017 com.demo_fake-crypto-lib 1.2.3 | Prioridad: 0.01

Archivo: src/main/com.demo/fake-crypto-lib/demo_133.java

*io.demo:fake-db-driver versions before 4.5.9 deserialize server-provided responses without type validation.***[Fix]** Upgrade io.demo:fake-db-driver to 4.5.9 immediately.

2. HTTP Client: Server-Side Request Forgery via malformed redirect handling - Demo 43

● HIGH

Tipo: engine_dependencies | CVE: CVE-2025-99014 io.example_demo-auth-lib 5.1.0 | Prioridad: 0.01

Archivo: src/main/io.example_demo-auth-lib/demo_43.java

org.example_demo-http-client versions below 2.1.4 do not validate redirect destinations when following 3xx responses.

[Fix] Upgrade org.example_demo-http-client to 2.1.4.

3. Blacklisted dependency: known malicious package in transitive graph - Demo 58

● HIGH

Tipo: black_list; engine_dependencies | CVE: CVE-2025-99027 com.example_demo-scheduler 2.0.0 | Prioridad: 0.01

Archivo: src/main/com.example_demo-scheduler/demo_58.java

A transitive dependency of the orders service pulls in org.fake_demo-serializer 0.9.1, which appears on the internal... security blacklist following the discovery of obfuscated exfiltration code in a pre...

[Fix] Remove org.fake_demo-serializer from the dependency graph. Replace with a vetted serialization alternative and verify no other transitive paths re-introduce the package.

4. Crypto Lib: Weak RSA key generation due to biased PRNG - Demo 103

● HIGH

Tipo: engine_dependencies | CVE: CVE-2025-99016 io.example_demo-auth-lib 5.1.0 | Prioridad: 0.01

Archivo: src/main/io.example_demo-auth-lib/demo_103.java

com.demo_fake-crypto-lib prior to 1.2.5 uses a PRNG with a measurable statistical bias when generating RSA prime candidates.

[Fix] Upgrade com.demo_fake-crypto-lib to 1.2.5.

5. Terraform: S3 backend state file has no encryption or access logging - Demo 113

● HIGH

Tipo: engine_iac | CVE: CVE-2025-99025 org.demo_fake-xml-parser 1.0.0 | Prioridad: 0.01

Archivo: src/main/org.demo_fake-xml-parser/demo_113.java

The Terraform remote state backend S3 bucket is configured without server-side encryption and without access logging.

[Fix] Enable SSE-KMS on the Terraform state bucket and configure S3 access logging to a separate audit bucket.

6. Container image running as root user without read-only filesystem - Demo 138

● HIGH

Tipo: engine_container | CVE: CVE-2025-99022 com.fake_demo-session-manager 2.3.4 | Prioridad: 0.01

Archivo: src/main/com.fake_demo-session-manager/demo_138.java

The Docker image for the accounts service runs processes as root (UID 0) and mounts the application volume as read-

[Fix] Define a non-root USER in the Dockerfile and set the root filesystem to read-only using securityContext.readOnlyRootFilesystem: true.

7. Auth Lib: JWT signature verification bypass with algorithm confusion - Demo 18

● MEDIUM

Tipo: engine_dependencies | CVE: CVE-2025-99018 com.fake_demo-session-manager 2.3.4 | Prioridad: 0.01

Archivo: src/main/com.fake_demo-session-manager/demo_18.java

io.example_demo-auth-lib before 5.1.3 accepts JWTs with the "none" algorithm if the header algorithm field is set to "None" (mixed case).

[Fix] Upgrade io.example_demo-auth-lib to 5.1.3 and explicitly reject the "none" algorithm in the JWT validation configuration.

8. Container image based on deprecated base OS with unpatched CVEs - Demo 23

● MEDIUM

Tipo: engine_container | CVE: CVE-2025-99023 io.demo_fake-template-engine 6.3.0 | Prioridad: 0.01

Archivo: src/main/io.demo/fake-template-engine/demo_23.java

The orders service container image is built on a base OS image that reached end-of-life and no longer receives security patches.

[Fix] Rebuild image using a maintained base image (e.g. alpine:3.19 or debian:bookworm-slim). Pin base image digest to prevent supply-chain substitution.

9. JSON Parser: Uncontrolled resource consumption via deeply nested input - Demo 73

● MEDIUM

Tipo: engine_dependencies | CVE: CVE-2025-99015 com.demo_fake-crypto-lib 1.2.3 | Prioridad: 0.01

Archivo: src/main/com.demo/fake-crypto-lib/demo_73.java

com.example:fake-json-parser versions before 3.0.3 do not impose limits on object nesting depth.

[Fix] Upgrade com.example:fake-json-parser to 3.0.3.

10. XML Parser: Billion laughs XML entity expansion attack - Demo 78

● MEDIUM

Tipo: engine_dependencies | CVE: CVE-2025-99020 com.fake_demo-session-manager 2.3.4 | Prioridad: 0.01

Archivo: src/main/com.fake/demo-session-manager/demo_78.java

org.demo:fake-xml-parser versions before 1.1.0 do not set limits on XML entity expansion.

[Fix] Upgrade org.demo:fake-xml-parser to 1.1.0.

11. Template Engine: Server-side template injection via user-controlled input - Demo 108

● MEDIUM

Tipo: engine_dependencies | CVE: CVE-2025-99021 org.demo_fake-serializer 0.9.1 | Prioridad: 0.01

Archivo: src/main/org.demo/fake-serializer/demo_108.java

io.demo:fake-template-engine 6.3.0 evaluates template expressions found in user input without sandboxing.

[Fix] Upgrade io.demo:fake-template-engine to 6.3.2 and always sanitize input before passing it to the template rendering context.

12. Kubernetes RBAC: ClusterRole binds wildcard verbs to core API group - Demo 143

● MEDIUM

Tipo: engine_iac | CVE: CVE-2025-99026 io.demo_fake-template-engine 6.3.0 | Prioridad: 0.01

Archivo: src/main/io.demo/fake-template-engine/demo_143.java

A ClusterRole definition in the Helm chart grants [""] verbs on core API resources including pods, secrets, and*

[Fix] Replace wildcard verbs with explicit minimal verb sets. Separate read and write roles. Upgrade scheduler to 2.0.2 to patch related scheduling flaw.

13. Scheduler: Denial of service via malformed cron expression - Demo 48

● LOW

Tipo: engine_dependencies | CVE: CVE-2025-99019 org.demo_fake-serializer 0.9.1 | Prioridad: 0.01

Archivo: src/main/org.demo/fake-serializer/demo_48.java

com.example:demo-scheduler version 2.0.0 does not validate cron expressions before parsing.

[Fix] Upgrade com.example:demo-scheduler to 2.0.2.

14. Secrets mounted as environment variables in container spec - Demo 53

● LOW

Tipo: engine_container | CVE: CVE-2025-99024 org.demo_fake-xml-parser 1.0.0 | Prioridad: 0.01

Archivo: src/main/org.demo/fake-xml-parser/demo_53.java

Database credentials and API keys are injected as environment variables in the Kubernetes pod specification using plain-text values.

[Fix] 1.1.0

15. Terraform module lacks required_providers version constraints - Demo 28

● INFO

Tipo: engine_iac | Prioridad: 0.00

Archivo: src/main/io.demo/fake-db-driver/demo_28.java

Several Terraform modules declare providers without pinning to a specific version range.

[Fix] 4.5.9

16. Container image has no defined HEALTHCHECK instruction - Demo 83

● INFO

Tipo: engine_container | Prioridad: 0.00

Archivo: src/main/io.demo/fake-template-engine/demo_83.java

The insurance service Dockerfile does not define a HEALTHCHECK instruction.

[Fix] Add HEALTHCHECK INTERVAL=30s TIMEOUT=5s CMD curl -f http://localhost:8080/actuator/health || exit 1 to the Dockerfile.

DEMO_004_FakeInsurance_MR_ms_polizas

Producto: Demo_DEMO004 | Vulnerabilidades: 16

1. DB Driver: Remote code execution via deserialization of untrusted data - Demo 104

● CRITICAL

Tipo: engine_dependencies | CVE: CVE-2025-99017 com.demo_example-cache 3.2.1 | Prioridad: 0.01

Archivo: src/main/com.demo/example-cache/demo_104.java

io.demo:fake-db-driver versions before 4.5.9 deserialize server-provided responses without type validation.

[Fix] Upgrade io.demo:fake-db-driver to 4.5.9 immediately.

2. HTTP Client: Server-Side Request Forgery via malformed redirect handling - Demo 14

● HIGH

Tipo: engine_dependencies | CVE: CVE-2025-99014 org.example_demo-http-client 2.1.0 | Prioridad: 0.01

Archivo: src/main/org.example/demo-http-client/demo_14.java

org.example:demo-http-client versions below 2.1.4 do not validate redirect destinations when following 3xx responses.

[Fix] Upgrade org.example:demo-http-client to 2.1.4.

3. Blacklisted dependency: known malicious package in transitive graph - Demo 29

● HIGH

Tipo: black_list; engine_dependencies | CVE: CVE-2025-99027 org.demo_fake-xml-parser 1.0.0 | Prioridad: 0.01

Archivo: src/main/org.demo/fake-xml-parser/demo_29.java

A transitive dependency of the orders service pulls in org.fake:demo-serializer 0.9.1, which appears on the internal

[Fix] Remove org.fake:demo-serializer from the dependency graph. Replace with a vetted serialization alternative and verify no other transitive paths re-introduce the package.

4. Crypto Lib: Weak RSA key generation due to biased PRNG - Demo 74

● HIGH

Tipo: engine_dependencies | CVE: CVE-2025-99016 org.example_demo-http-client 2.1.0 | Prioridad: 0.01

Archivo: src/main/org.example/demo-http-client/demo_74.java

com.demo:fake-crypto-lib prior to 1.2.5 uses a PRNG with a measurable statistical bias when generating RSA prime candidates.

[Fix] Upgrade com.demo:fake-crypto-lib to 1.2.5.

5. Terraform: S3 backend state file has no encryption or access logging - Demo 84

● HIGH

Tipo: engine_iac | CVE: CVE-2025-99025 org.demo_fake-serializer 0.9.1 | Prioridad: 0.01

Archivo: src/main/org.demo/fake-serializer/demo_84.java

*The Terraform remote state backend S3 bucket is configured without server-side encryption and without access logging.***[Fix]** Enable SSE-KMS on the Terraform state bucket and configure S3 access logging to a separate audit bucket.**6. Container image running as root user without read-only filesystem - Demo 109**

● HIGH

Tipo: engine_container | CVE: CVE-2025-99022 com.demo_fake-crypto-lib 1.2.3 | Prioridad: 0.01

Archivo: src/main/com.demo/fake-crypto-lib/demo_109.java

*The Docker image for the accounts service runs processes as root (UID 0) and mounts the application volume as read-write.***[Fix]** Define a non-root USER in the Dockerfile and set the root filesystem to read-only using securityContext.readOnlyRootFilesystem: true.**7. JSON Parser: Uncontrolled resource consumption via deeply nested input - Demo 44**

● MEDIUM

Tipo: engine_dependencies | CVE: CVE-2025-99015 com.demo_example-cache 3.2.1 | Prioridad: 0.01

Archivo: src/main/com.demo/example-cache/demo_44.java

*com.example:fake-json-parser versions before 3.0.3 do not impose limits on object nesting depth.***[Fix]** Upgrade com.example:fake-json-parser to 3.0.3.**8. XML Parser: Billion laughs XML entity expansion attack - Demo 49**

● MEDIUM

Tipo: engine_dependencies | CVE: CVE-2025-99020 com.demo_fake-crypto-lib 1.2.3 | Prioridad: 0.01

Archivo: src/main/com.demo/fake-crypto-lib/demo_49.java

*org.demo:fake-xml-parser versions before 1.1.0 do not set limits on XML entity expansion.***[Fix]** Upgrade org.demo:fake-xml-parser to 1.1.0.**9. Template Engine: Server-side template injection via user-controlled input - Demo 79**

● MEDIUM

Tipo: engine_dependencies | CVE: CVE-2025-99021 io.example_demo-auth-lib 5.1.0 | Prioridad: 0.01

Archivo: src/main/io.example/demo-auth-lib/demo_79.java

*io.demo:fake-template-engine 6.3.0 evaluates template expressions found in user input without sandboxing.***[Fix]** Upgrade io.demo:fake-template-engine to 6.3.2 and always sanitize input before passing it to the template rendering context.**10. Kubernetes RBAC: ClusterRole binds wildcard verbs to core API group - Demo 114**

● MEDIUM

Tipo: engine_iac | CVE: CVE-2025-99026 com.fake_demo-session-manager 2.3.4 | Prioridad: 0.01

Archivo: src/main/com.fake/demo-session-manager/demo_114.java

A ClusterRole definition in the Helm chart grants [""] verbs on core API resources including pods, secrets, and configmaps.***[Fix]** Replace wildcard verbs with explicit minimal verb sets. Separate read and write roles. Upgrade scheduler to 2.0.2 to patch related scheduling flaw.

11. Auth Lib: JWT signature verification bypass with algorithm confusion - Demo 134

● MEDIUM

Tipo: engine_dependencies | CVE: CVE-2025-99018 org.example_demo-http-client 2.1.0 | Prioridad: 0.01

Archivo: src/main/org.example/demo-http-client/demo_134.java

*io.example:demo-auth-lib before 5.1.3 accepts JWTs with the "none" algorithm if the header algorithm field is set to "None" (mixed case).***[Fix]** Upgrade io.example:demo-auth-lib to 5.1.3 and explicitly reject the "none" algorithm in the JWT validation configuration.**12. Container image based on deprecated base OS with unpatched CVEs - Demo 139**

● MEDIUM

Tipo: engine_container | CVE: CVE-2025-99023 io.example_demo-auth-lib 5.1.0 | Prioridad: 0.01

Archivo: src/main/io.example/demo-auth-lib/demo_139.java

*The orders service container image is built on a base OS image that reached end-of-life and no longer receives security... patches.***[Fix]** Rebuild image using a maintained base image (e.g. alpine:3.19 or debian:bookworm-slim). Pin base image digest to prevent supply-chain substitution.**13. Scheduler: Denial of service via malformed cron expression - Demo 19**

● LOW

Tipo: engine_dependencies | CVE: CVE-2025-99019 io.example_demo-auth-lib 5.1.0 | Prioridad: 0.01

Archivo: src/main/io.example/demo-auth-lib/demo_19.java

*com.example:demo-scheduler version 2.0.0 does not validate cron expressions before parsing.***[Fix]** Upgrade com.example:demo-scheduler to 2.0.2.**14. Secrets mounted as environment variables in container spec - Demo 24**

● LOW

Tipo: engine_container | CVE: CVE-2025-99024 org.demo_fake-serializer 0.9.1 | Prioridad: 0.01

Archivo: src/main/org.demo/fake-serializer/demo_24.java

*Database credentials and API keys are injected as environment variables in the Kubernetes pod specification using plain-text values.***15. Container image has no defined HEALTHCHECK instruction - Demo 54**

● INFO

Tipo: engine_container | Prioridad: 0.00

Archivo: src/main/com.fake/demo-session-manager/demo_54.java

*The insurance service Dockerfile does not define a HEALTHCHECK instruction.***[Fix]** Add HEALTHCHECK INTERVAL=30s TIMEOUT=5s CMD curl -f http://localhost:8080/actuator/health || exit 1 to the Dockerfile.**16. Terraform module lacks required_providers version constraints - Demo 144**

● INFO

Tipo: engine_iac | Prioridad: 0.00

Archivo: src/main/org.demo/fake-serializer/demo_144.java

*Several Terraform modules declare providers without pinning to a specific version range.***> Servicios de Test****DEMO_002_FakeShop_TEST_ms_pedidos_test**

Producto: Demo_DEMO002 | Vulnerabilidades: 16

1. DB Driver: Remote code execution via deserialization of untrusted data - Demo 75**● CRITICAL**

Tipo: engine_dependencies | CVE: CVE-2025-99017 com.example_fake-json-parser 3.0.1 | Prioridad: 0.01

Archivo: src/main/com.example/fake-json-parser/demo_75.java

*io.demo.fake-db-driver versions before 4.5.9 deserialize server-provided responses without type validation.***[Fix]** Upgrade io.demo:fake-db-driver to 4.5.9 immediately.**2. Crypto Lib: Weak RSA key generation due to biased PRNG - Demo 45****● HIGH**

Tipo: engine_dependencies | CVE: CVE-2025-99016 org.fake_demo-logger 1.8.5 | Prioridad: 0.01

Archivo: src/main/org.fake/demo-logger/demo_45.java

*com.demo.fake-crypto-lib prior to 1.2.5 uses a PRNG with a measurable statistical bias when generating RSA prime... candidates.***[Fix]** Upgrade com.demo:fake-crypto-lib to 1.2.5.**3. Terraform: S3 backend state file has no encryption or access logging - Demo 55****● HIGH**

Tipo: engine_iac | CVE: CVE-2025-99025 io.example_demo-auth-lib 5.1.0 | Prioridad: 0.01

Archivo: src/main/io.example/demo-auth-lib/demo_55.java

*The Terraform remote state backend S3 bucket is configured without server-side encryption and without access logging.***[Fix]** Enable SSE-KMS on the Terraform state bucket and configure S3 access logging to a separate audit bucket.**4. Container image running as root user without read-only filesystem - Demo 80****● HIGH**

Tipo: engine_container | CVE: CVE-2025-99022 com.demo_example-cache 3.2.1 | Prioridad: 0.01

Archivo: src/main/com.demo/example-cache/demo_80.java

*The Docker image for the accounts service runs processes as root (UID 0) and mounts the application volume as read-write.***[Fix]** Define a non-root USER in the Dockerfile and set the root filesystem to read-only using securityContext.readOnlyRootFilesystem: true.**5. HTTP Client: Server-Side Request Forgery via malformed redirect handling - Demo 130****● HIGH**

Tipo: engine_dependencies | CVE: CVE-2025-99014 com.example_demo-scheduler 2.0.0 | Prioridad: 0.01

Archivo: src/main/com.example/demo-scheduler/demo_130.java

*org.example:demo-http-client versions below 2.1.4 do not validate redirect destinations when following 3xx responses.***[Fix]** Upgrade org.example:demo-http-client to 2.1.4.**6. Blacklisted dependency: known malicious package in transitive graph - Demo 145****● HIGH**

Tipo: black_list; engine_dependencies | CVE: CVE-2025-99027 com.demo_fake-crypto-lib 1.2.3 | Prioridad: 0.01

Archivo: src/main/com.demo/fake-crypto-lib/demo_145.java

*A transitive dependency of the orders service pulls in org.fake:demo-serializer 0.9.1, which appears on the internal security blacklist following the discovery of obfuscated exfiltration code in a pre...***[Fix]** Remove org.fake:demo-serializer from the dependency graph. Replace with a vetted serialization alternative and verify no other transitive paths re-introduce the package.

7. JSON Parser: Uncontrolled resource consumption via deeply nested input - Demo 15

● MEDIUM

Tipo: engine_dependencies | CVE: CVE-2025-99015 com.example_fake-json-parser 3.0.1 | Prioridad: 0.01

Archivo: src/main/com.example/fake-json-parser/demo_15.java

*com.example:fake-json-parser versions before 3.0.3 do not impose limits on object nesting depth.***[Fix]** Upgrade com.example:fake-json-parser to 3.0.3.**8. XML Parser: Billion laughs XML entity expansion attack - Demo 20**

● MEDIUM

Tipo: engine_dependencies | CVE: CVE-2025-99020 com.demo_example-cache 3.2.1 | Prioridad: 0.01

Archivo: src/main/com.demo/example-cache/demo_20.java

*org.demo:fake-xml-parser versions before 1.1.0 do not set limits on XML entity expansion.***[Fix]** Upgrade org.demo:fake-xml-parser to 1.1.0.**9. Template Engine: Server-side template injection via user-controlled input - Demo 50**

● MEDIUM

Tipo: engine_dependencies | CVE: CVE-2025-99021 org.example_demo-http-client 2.1.0 | Prioridad: 0.01

Archivo: src/main/org.example/demo-http-client/demo_50.java

*io.demo:fake-template-engine 6.3.0 evaluates template expressions found in user input without sandboxing.***[Fix]** Upgrade io.demo:fake-template-engine to 6.3.2 and always sanitize input before passing it to the template rendering context.**10. Kubernetes RBAC: ClusterRole binds wildcard verbs to core API group - Demo 85**

● MEDIUM

Tipo: engine_iac | CVE: CVE-2025-99026 com.demo_fake-crypto-lib 1.2.3 | Prioridad: 0.01

Archivo: src/main/com.demo/fake-crypto-lib/demo_85.java

A ClusterRole definition in the Helm chart grants [""] verbs on core API resources including pods, secrets, and configmaps.***[Fix]** Replace wildcard verbs with explicit minimal verb sets. Separate read and write roles. Upgrade scheduler to 2.0.2 to patch related scheduling flaw.**11. Auth Lib: JWT signature verification bypass with algorithm confusion - Demo 105**

● MEDIUM

Tipo: engine_dependencies | CVE: CVE-2025-99018 org.fake_demo-logger 1.8.5 | Prioridad: 0.01

Archivo: src/main/org.fake/demo-logger/demo_105.java

*io.example:demo-auth-lib before 5.1.3 accepts JWTs with the "none" algorithm if the header algorithm field is set to***[Fix]** Upgrade io.example:demo-auth-lib to 5.1.3 and explicitly reject the "none" algorithm in the JWT validation configuration.**12. Container image based on deprecated base OS with unpatched CVEs - Demo 110**

● MEDIUM

Tipo: engine_container | CVE: CVE-2025-99023 org.example_demo-http-client 2.1.0 | Prioridad: 0.01

Archivo: src/main/org.example/demo-http-client/demo_110.java

*The orders service container image is built on a base OS image that reached end-of-life and no longer receives security patches.***[Fix]** Rebuild image using a maintained base image (e.g. alpine:3.19 or debian:bookworm-slim). Pin base image digest to prevent supply-chain substitution.

13. Scheduler: Denial of service via malformed cron expression - Demo 135

LOW

Tipo: engine_dependencies | CVE: CVE-2025-99019 com.example_fake-json-parser 3.0.1 | Prioridad: 0.01
Archivo: src/main/com.example/fake-json-parser/demo_135.java
com.example:demo-scheduler version 2.0.0 does not validate cron expressions before parsing.
[Fix] Upgrade com.example:demo-scheduler to 2.0.2.

14. Secrets mounted as environment variables in container spec - Demo 140

LOW

Tipo: engine_container | CVE: CVE-2025-99024 com.demo_example-cache 3.2.1 | Prioridad: 0.01
Archivo: src/main/com.demo/example-cache/demo_140.java
Database credentials and API keys are injected as environment variables in the Kubernetes pod specification using plaintext values.
[Fix] 3.3.0

15. Container image has no defined HEALTHCHECK instruction - Demo 25

INFO

Tipo: engine_container | Prioridad: 0.00
Archivo: src/main/com.demo/fake-crypto-lib/demo_25.java
The insurance service Dockerfile does not define a HEALTHCHECK instruction.
[Fix] Add HEALTHCHECK INTERVAL=30s TIMEOUT=5s CMD curl -f http://localhost:8080/actuator/health || exit 1 to the Dockerfile.

16. Terraform module lacks required_providers version constraints - Demo 115

INFO

Tipo: engine_iac | Prioridad: 0.00
Archivo: src/main/io.example/demo-auth-lib/demo_115.java
Several Terraform modules declare providers without pinning to a specific version range.
[Fix] 5.1.3

SECCIÓN 05

Top 10 Vulnerabilidades Más Urgentes

Nota: Priorización basada en CVSS Score × 0.7 + EPSS Percentil × 0.3. Mayor puntaje combinado = mayor urgencia de remediación.

#1

DB Driver: Remote code execution via deserialization of untrusted...

CRITICAL

CVSS: 9.8 | EPSS: 0.0190% (P30%) | Score: 7.77
Componente: com.demo_fake-crypto-lib v1.2.3 | Servicio: DEMO_003_FakeLogistic_MR_ms_envios
[Fix] Upgrade io.demo:fake-db-driver to 4.5.9 immediately.

#2

DB Driver: Remote code execution via deserialization of untrusted...

CRITICAL

CVSS: 9.8 | EPSS: 0.0680% (P26%) | Score: 7.63
Componente: com.example_demo-scheduler v2.0.0 | Servicio: DEMO_001_FakeBank_MR_ms_cuentas
[Fix] Upgrade io.demo:fake-db-driver to 4.5.9 immediately.

#3 Broken Authentication: Session tokens with insufficient entropy -...**● CRITICAL**

CVSS: 9.8 | EPSS: 0.0500% (P24%) | Score: 7.59

Componente: com.fake_demo-session-manager v2.3.4 | Servicio: DEMO_002_FakeShop_TEST_ms_pedidos_test

[Fix] Upgrade com.fake:demo-session-manager to 3.0.0 or replace token generation with java.security.SecureRandom with at least 128-bit entropy.**#4 Broken Authentication: Session tokens with insufficient entropy -...****● CRITICAL**

CVSS: 9.8 | EPSS: 0.0320% (P23%) | Score: 7.54

Componente: com.demo_fake-crypto-lib v1.2.3 | Servicio: DEMO_001_FakeBank_MR_ms_cuentas

[Fix] Upgrade com.fake:demo-session-manager to 3.0.0 or replace token generation with java.security.SecureRandom with at least 128-bit entropy.**#5 AWS S3 bucket with public read access and no encryption at rest -...****● CRITICAL**

CVSS: 9.1 | EPSS: 0.0160% (P39%) | Score: 7.53

Componente: org.fake_demo-logger v1.8.5 | Servicio: DEMO_004_FakeInsurance_MR_ms_polizas

[Fix] Enable SSE-S3 or SSE-KMS encryption. Remove public-read ACL and enforce bucket policy to deny public access. Upgrade cache lib to 3.3.0.**#6 Broken Authentication: Session tokens with insufficient entropy -...****● CRITICAL**

CVSS: 9.8 | EPSS: 0.0410% (P22%) | Score: 7.52

Componente: io.demo_fake-db-driver v4.5.2 | Servicio: DEMO_003_FakeLogistic_MR_ms_envios

[Fix] Upgrade com.fake:demo-session-manager to 3.0.0 or replace token generation with java.security.SecureRandom with at least 128-bit entropy.**#7 AWS S3 bucket with public read access and no encryption at rest -...****● CRITICAL**

CVSS: 9.1 | EPSS: 0.0950% (P37%) | Score: 7.49

Componente: org.demo_fake-xml-parser v1.0.0 | Servicio: DEMO_002_FakeShop_TEST_ms_pedidos_test

[Fix] Enable SSE-S3 or SSE-KMS encryption. Remove public-read ACL and enforce bucket policy to deny public access. Upgrade cache lib to 3.3.0.**#8 AWS S3 bucket with public read access and no encryption at rest -...****● CRITICAL**

CVSS: 9.1 | EPSS: 0.0900% (P35%) | Score: 7.43

Componente: org.example_demo-http-client v2.1.0 | Servicio: DEMO_003_FakeLogistic_MR_ms_envios

[Fix] Enable SSE-S3 or SSE-KMS encryption. Remove public-read ACL and enforce bucket policy to deny public access. Upgrade cache lib to 3.3.0.**#9 DB Driver: Remote code execution via deserialization of untrusted...****● CRITICAL**

CVSS: 9.8 | EPSS: 0.0750% (P17%) | Score: 7.38

Componente: com.demo_example-cache v3.2.1 | Servicio: DEMO_004_FakeInsurance_MR_ms_polizas

[Fix] Upgrade io.demo:fake-db-driver to 4.5.9 immediately.**#10 AWS S3 bucket with public read access and no encryption at rest -...****● CRITICAL**

CVSS: 9.1 | EPSS: 0.0120% (P32%) | Score: 7.34

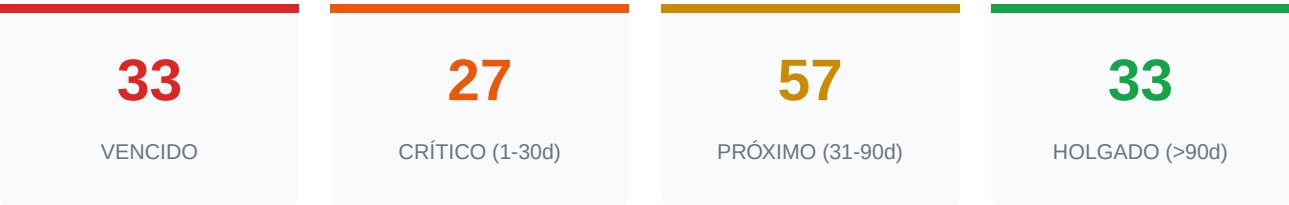
Componente: org.demo_fake-serializer v0.9.1 | Servicio: DEMO_001_FakeBank_MR_ms_cuentas

[Fix] Enable SSE-S3 or SSE-KMS encryption. Remove public-read ACL and enforce bucket policy to deny public access. Upgrade cache lib to 3.3.0.

SECCIÓN 06

Análisis de SLA

Estado de cumplimiento de SLA. Vulnerabilidades agrupadas por tiempo restante para vencimiento.



Estado SLA	Cantidad	% del Total
Vencido (0 días o menos)	33	22.0%
Crítico (1-30 días)	27	18.0%
Próximo (31-90 días)	57	38.0%
Holgado (>90 días)	33	22.0%

Antigüedad promedio de vulnerabilidades: 195 días

● Vulnerabilidades con SLA Crítico o Vencido

Severidad	Días Restantes	Servicio
● CRITICAL	VENCIDO	DEMO_001_FakeBank_MR_ms_cuentas
● CRITICAL	VENCIDO	DEMO_004_FakeInsurance_MR_ms_polizas
● CRITICAL	VENCIDO	DEMO_002_FakeShop_MR_ms_pedidos
● CRITICAL	VENCIDO	DEMO_002_FakeShop_TEST_ms_pedidos_test
● CRITICAL	VENCIDO	DEMO_003_FakeLogistic_MR_ms_envios
● CRITICAL	VENCIDO	DEMO_001_FakeBank_MR_ms_cuentas
● CRITICAL	VENCIDO	DEMO_004_FakeInsurance_MR_ms_polizas

Severidad	Días Restantes	Servicio
● CRITICAL	VENCIDO	DEMO_002_FakeShop_MR_ms_pedidos
● CRITICAL	VENCIDO	DEMO_002_FakeShop_TEST_ms_pedidos_test
● CRITICAL	VENCIDO	DEMO_003_FakeLogistic_MR_ms_envios
● CRITICAL	VENCIDO	DEMO_001_FakeBank_MR_ms_cuentas
● CRITICAL	VENCIDO	DEMO_004_FakeInsurance_MR_ms_polizas
● CRITICAL	VENCIDO	DEMO_002_FakeShop_MR_ms_pedidos
● CRITICAL	VENCIDO	DEMO_002_FakeShop_TEST_ms_pedidos_test
● CRITICAL	VENCIDO	DEMO_003_FakeLogistic_MR_ms_envios

SECCIÓN 07

Vulnerabilidades Compartidas entre Servicios

CVEs que aparecen en múltiples servicios. Solucionar una dependencia compartida puede cerrar varias vulnerabilidades simultáneamente.

Total CVEs compartidos entre 2+ servicios: 0

No se encontraron CVEs compartidos entre múltiples servicios.

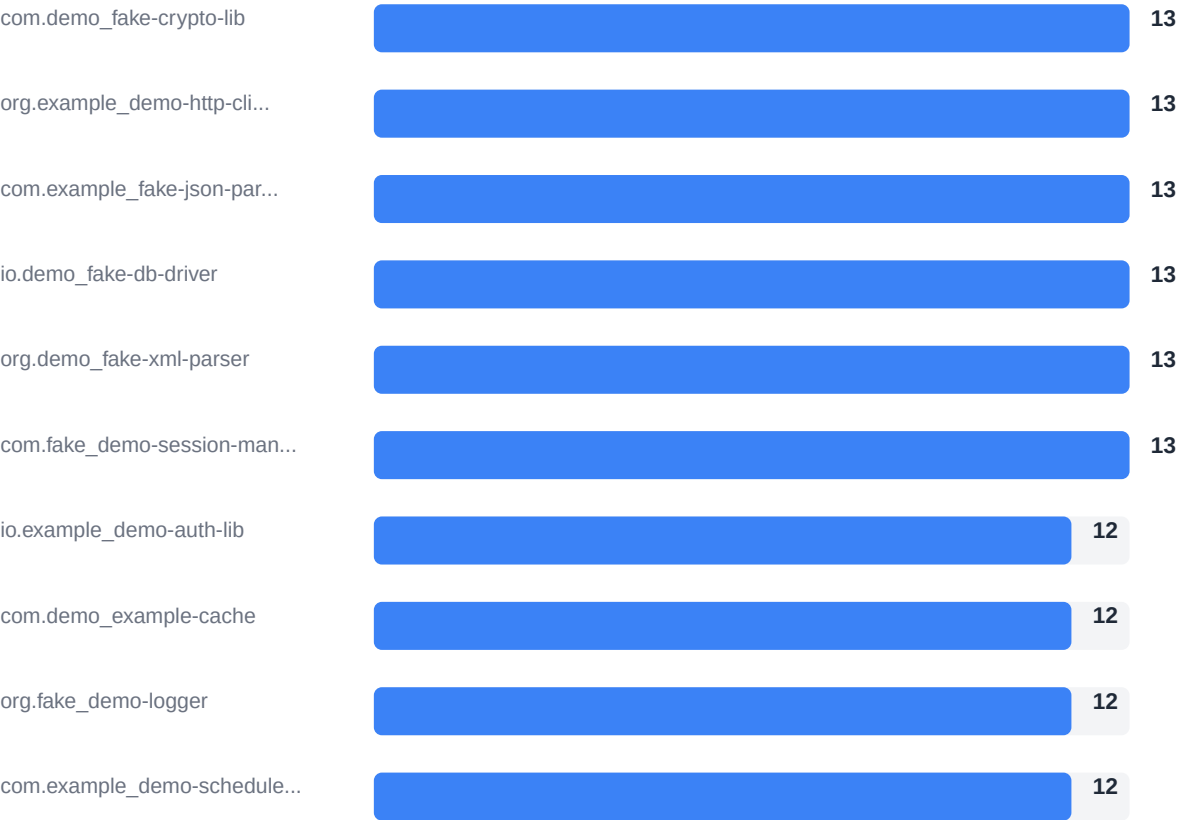
SECCIÓN 08

Componentes Más Vulnerables

Librerías/componentes que acumulan más vulnerabilidades. Actualizar estos componentes tiene mayor impacto en la reducción de riesgo.

Componente	Vulnerabilidades	Versiones	Servicios
com.demo_fake-crypto-lib	13	1.2.3	5
org.example_demo-http-client	13	2.1.0	5
com.example_fake-json-parser	13	3.0.1	5
io.demo_fake-db-driver	13	4.5.2	5
org.demo_fake-xml-parser	13	1.0.0	5
com.fake_demo-session-manager	13	2.3.4	5
io.example_demo-auth-lib	12	5.1.0	5
com.demo_example-cache	12	3.2.1	5
org.fake_demo-logger	12	1.8.5	5
com.example_demo-scheduler	12	2.0.0	5
io.demo_fake-template-engine	12	6.3.0	5
org.demo_fake-serializer	12	0.9.1	5

Top 10 Componentes con más vulnerabilidades



SECCIÓN 09
Cobertura de Mitigación

Porcentaje de vulnerabilidades con fix/versión disponible vs las que no tienen solución conocida.



Estado	Cantidad	% del Total
Con fix disponible	144	96.0%
Sin fix conocido	6	4.0%

Cobertura de Mitigación



Sin Fix Conocido por Severidad

Severidad	Sin Fix	
MEDIUM	2	33.3%
LOW	2	33.3%
INFO	2	33.3%

SECCIÓN 10

Herramientas de Detección y Ambientes

Vulnerabilidades por Herramienta de Detección

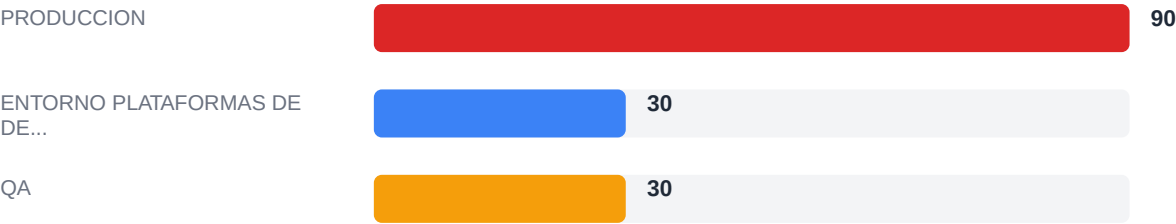
Herramienta	Cantidad	% del Total
Trivy Scan	65	43.3%
fluidattacks	45	30.0%
AWS Config	25	16.7%
Checkov	15	10.0%

Vulnerabilidades por Ambiente

Ambiente	Cantidad	% del Total
PRODUCCION	90	60.0%

Ambiente	Cantidad	% del Total
ENTORNO PLATAFORMAS DE DESARROLLO	30	20.0%
QA	30	20.0%

Distribución por Ambiente



● Estado de Riesgo

Estado de Riesgo	Cantidad	% del Total
Risk Active	150	100.0%